Empirical Evaluation and Post-Quantum Hardening of Lightweight Cloud-IoT Mutual Authentication: A Reproducible Formal Analysis

Surya Pratap Singh Raikuni, *Student Member, IEEE*, and **Dr. Karthika V**, *Senior Member, IEEE*
Department of Cybersecurity, School of Computer Science and Engineering (SCOPE)
Vellore Institute of Technology (VIT Chennai), Chennai 600127, India
Registration Number: 24BYB1114 | Research Evaluation & Verification Group

Abstract*—Mutual Authentication and Key Agreement (MAKA) protocols are foundational for securing communications between resource-constrained Internet of Things (IoT) devices and untrusted cloud platforms. While lightweight symmetric protocols claiming ultra-low computation and provable security frequently appear in literature, subtle bit-width ambiguities, unverified assumptions, and a lack of cyber-physical wireless evaluations hinder reliable deployment. This paper presents CryptoMAKA, an experimental evaluation and formal verification platform. First, we implement a bitwise normalized reconstruction of the recent three-party hash/XOR protocol proposed by Ju and Park (Sensors 2023) alongside an authenticated NIST P-256 Elliptic Curve Diffie-Hellman (ECDH) baseline. Second, we introduce an architectural optimization—a Reduced-Round-Trip (3-pass) scheme that aggregates Control Server authentication responses, reducing wireless airtime latency by 25% to 33%. Third, addressing the quantum threat horizon (Shor's algorithm), we integrate a post-quantum prototype utilizing NIST FIPS 203 Module-Lattice-Based Key-Encapsulation Mechanism (ML-KEM-768). All protocols are subjected to active Dolev-Yao threat penetration (replay, tampering, impersonation, MitM, and KCI) and formally verified in the Inria ProVerif applied pi-calculus, proving 13 out of 13 formal theorems covering session key secrecy and injective correspondence. Finally, we model physical layer propagation across LoRaWAN, NB-IoT, LTE-M, and 5G alongside embedded microjoule energy consumption on an ARM Cortex-M4 MCU. Experimental results demonstrate that while post-quantum KEMs deliver quantum immunity, their 2,272-byte wire footprint incurs severe fragmentation penalties in low-power wide-area networks, highlighting the imperative trade-off between post-quantum resilience and battery longevity in edge IoT architectures.

***Index Terms*—Mutual Authentication, Key Agreement (MAKA), Cloud-IoT Security, Formal Verification, ProVerif, Dolev-Yao Threat Model, Post-Quantum Cryptography (ML-KEM-768), Low-Power Wide-Area Networks (LPWAN), Energy Modeling.**

I. INTRODUCTION

The Internet of Things (IoT) paradigm connects billions of resource-constrained sensors, embedded controllers, and industrial actuators to cloud analytics infrastructure across smart grids, automated transportation, and remote patient healthcare. In these distributed architectures, telemetry and actuation commands traverse untrusted public wireless channels susceptible to eavesdropping, packet manipulation, replay, and malicious server impersonation. Establishing mutual authentication and an ephemeral, forward-secure shared session key is therefore critical.

Conventional transport security protocols such as TLS 1.3 (RFC 8446) [6] rely on public-key cryptography—principally Elliptic Curve Cryptography (ECC) and digital signatures. While mathematically mature, ECC scalar point multiplication imposes non-trivial computational and energy penalties on low-end 8-bit to 32-bit microcontrollers powered by small lithium coin cells. Consequently, research has surged into ultra-lightweight three-party MAKA protocols utilizing cryptographic hash functions (e.g., SHA-256) and bitwise exclusive-OR (XOR) operations, mediated by a centralized Control Server (CS) or Registration Center (RC) [1], [5], [7], [8].

A. Limitations of Existing Approaches

Despite the proliferation of lightweight MAKA proposals, an analysis of the contemporary literature reveals three critical shortcomings:

- **Specification Ambiguity and Normalization Deficit:** Theoretical protocol specifications frequently concatenate elements of heterogeneous lengths (such as 128-bit nonces, 256-bit hashes, 32-bit timestamps, and variable biometric strings) under XOR masks without deterministic bit-padding or truncation definitions. In physical software implementations, mismatched bit lengths trigger runtime exceptions or insecure truncated outputs.
- **Multi-Hop Round-Trip Bottlenecks:** Reference three-party protocols (including Ju and Park [1]) enforce a rigid four-pass serial sequence (User -> Cloud -> Auth Server -> Cloud -> User). In Low-Power Wide-Area Networks (LPWAN) such as LoRaWAN and

NB-IoT, each additional round-trip pass incurs high transmission airtime delays and substantial RF transmitter battery expenditure.

• **The Post-Quantum Vulnerability Horizon:** Asymmetric baselines rely entirely on the hardness of the Elliptic Curve Discrete Logarithm Problem (ECDLP). With the advent of fault-tolerant quantum computing running Shor's algorithm, all classical public-key schemes will be compromised in polynomial time O(log N). Practical migration pathways toward post-quantum lattice primitives (e.g., NIST FIPS 203 ML-KEM) remain largely unbenchmarked under constrained IoT channel dynamics.

B. Explicit Major Contributions

To resolve these limitations, this paper establishes a reproducible experimental testbed and formal verification framework. Specifically, our major contributions are:

1. **Normalized Reference Reconstruction:** We implement a fully normalized, constant-time software reference of the Ju-Park 2023 protocol [1], strictly enforcing 256-bit alignment across all pseudonyms, nonces, and authenticators, accompanied by a fuzzy extractor biometric model.

2. **Proposed Reduced-Round-Trip (3-Pass) Extension:** We design an architectural optimization that aggregates the Authentication Server's response into a dual-ticket broadcast payload, reducing message passes from 4 to 3 and saving 25% to 33% in LPWAN transmission airtime.

3. **Formal Automated Proofs (ProVerif 2.05):** We develop comprehensive applied pi-calculus models proving 100% of security claims (13 out of 13 theorems) covering session key secrecy and injective mutual authentication under unbounded session concurrency.

4. **Multi-Radio Wireless & MCU Energy Profiling:** We benchmark physical transmission airtimes across LoRaWAN, NB-IoT, LTE-M, and 5G, and measure computational microjoule energy consumption on an ARM Cortex-M4 MCU.

5. **Post-Quantum (ML-KEM-768) Empirical Trade-off:** We integrate the finalized NIST FIPS 203 standard [3], quantifying the exact wire footprint expansion (2,272 bytes vs. 384 bytes) and packet fragmentation cost for quantum-safe IoT security.

II. RELATED WORK

Numerous lightweight mutual authentication protocols have been proposed for cloud-IoT networks. Turkanovic et al. [7] proposed a hash-based scheme for heterogeneous wireless sensor networks; however, subsequent cryptanalysis revealed vulnerabilities to offline password guessing and user impersonation. Amin and Biswas [8] introduced a multi-gateway architecture, but it suffered from sensor node capture vulnerabilities.

Challa et al. [5] integrated ECC point multiplication with user biometrics to guarantee forward secrecy. While secure against classical adversaries, ECC schemes incur significant computational overhead (4.15 ms execution time) and remain fundamentally broken under quantum Shor cryptanalysis.

In 2023, Ju and Park [1] published a lightweight three-party protocol for cloud-assisted IoT utilizing SHA-256, dynamic pseudonyms, and fuzzy extractors. Although conceptually sound, its lack of byte normalization and high 4-pass round-trip overhead leave critical deployment gaps. As shown in Table I, our work provides the first unified framework benchmarking normalized symmetric, modern elliptic curve, and post-quantum lattice paradigms.

Scheme	Primitive	Passes	PFS	Formal Tool	Quantum Safe
Turkanovic [7]	Hash / XOR	3	No	AVISPA	No (Grover)
Amin et al. [8]	Hash / XOR	4	Partial	ProVerif	No (Grover)
Challa et al. [5]	ECC P-256	3	Yes	AVISPA	Broken (Shor)
Ju & Park [1]	Hash / XOR	4	Partial	ProVerif	No (Grover)
TLS 1.3 [6]	ECDH P-256	2	Yes	Tamarin	Broken (Shor)
CryptoMAKA (Ours)	**Multi-Hybrid**	**2–4**	**Full**	**ProVerif 2.05**	**YES (FIPS 203)**

Table I: Comparative Literature Analysis of Cloud-IoT Authentication Protocols.

III. PROPOSED METHODOLOGY

The system architecture of CryptoMAKA Lab comprises three communicating entities operating within a Cloud-IoT topology: User / Edge Device (Ui), Cloud Server (CSj), and Control / Authentication Server (ASk). All wire channels are assumed to be under full control of a Dolev-Yao adversary [4] capable of intercepting, altering, injecting, and replaying packets.

A. Ju-Park 2023 Normalized Handshake Equations

In the normalized reference handshake, Ui computes: M1 = { PID_i, C_U, V_i, T1 }, where C_U = h(ID_i || PW_i || σ_i) ⊕ N_i, and V_i = h(PID_i || C_U || N_i || T1). Cloud Server CSj verifies freshness |T_cur - T1| ≤ ΔT, appends nonce N_c and timestamp T2, computing C_CS = h(C_U || T1) ⊕ N_c, and forwards M2 to ASk. Authentication Server ASk authenticates both parties using master secret x, and returns M3. Finally, CSj computes session key SK = h(PID_i || SID_j || N_i || N_c || N_s) and forwards M4 to Ui. To resolve bit-width ambiguities, all hashes are deterministically aligned to 256 bits, nonces to 128 bits, and biometric strings are normalized via fuzzy extractor Gen/Rep routines with 12% Hamming tolerance.

B. Proposed Reduced-Round-Trip (3-Pass) Optimization

To eliminate the high airtime latency of the 4th message hop, our proposed extension redesigns Message 3 from ASk into an aggregated response ticket broadcast simultaneously to Cloud Server and User: M3_CS and M3_U. The algorithmic procedure is defined as follows:

Algorithm 1: Proposed Reduced-Round-Trip (3-Pass) MAKA Procedure
Input: User U_i, Cloud CS_j, Authentication Server AS_k
1: $U_i \rightarrow CS_j : M_1 = \{ PID_i, Q_U, Auth_U, T_1 \}$
2: CS_j verifies T_1, computes Q_{CS}, forwards $M_2 = \{ M_1, Q_{CS}, T_2 \} \rightarrow AS_k$
3: AS_k authenticates U_i and CS_j concurrently via master key x
4: AS_k generates N_{AS}, computes dual tickets: $Ticket_{CS}$ and $Ticket_U$
5: $AS_k \rightarrow (CS_j, U_i) : M_3 = \{ Ticket_{CS}, Ticket_U, T_3 \}$ (Simultaneous Multicast)
6: CS_j derives $SK = h(Q_U \| Q_{CS} \| N_{AS})$
7: U_i verifies $Ticket_U$, derives identical $SK = h(Q_U \| Q_{CS} \| N_{AS})$
Output: Mutual authentication confirmed; shared session key established in 3 passes.

C. Post-Quantum Lattice KEM Integration (ML-KEM-768)

To provide forward security against quantum adversaries running Shor's algorithm, we integrate the newly finalized NIST FIPS 203 ML-KEM-768 standard [3]. Security reduces to Module Learning With Errors (M-LWE) over polynomial ring R_q with q = 3329 and module dimension k = 3. Ui generates lattice keypair (pk_U, sk_U), Cloud Server encapsulates shared secret ss = ML-KEM.Encaps(pk_U) producing 1,088-byte ciphertext c_CS, and Ui decapsulates ss = ML-KEM.Decaps(c_CS, sk_U), deriving session key SK.

IV. RESULTS AND DISCUSSION

Empirical benchmarks were executed on an x86_64 host (Intel Core @ 3.6 GHz, 32 GB RAM, Python 3.12 with OpenSSL 3.3.2 C-bindings). Embedded MCU energy and timing were calibrated against an ARM Cortex-M4 microcontroller running at 64 MHz, 3.3 V operating voltage, with active draw 15 mA (P_comp = 49.5 mW) and RF transmitter power P_tx = 120 mW. All benchmark measurements represent statistical aggregates over 1,000 independent deterministic executions.

A. Host Computation & Communication Overhead

As detailed in Table II, the reference Ju-Park protocol executes in 0.82 ms with 384 bytes wire payload. Our proposed Reduced-RTT optimization lowers execution time to 0.61 ms (a 25.6% speedup) while cutting wire payload to 288 bytes. ECC P-256 requires 4.15 ms—over 5 times slower than Ju-Park—due to the mathematical complexity of elliptic curve point multiplication. ML-KEM-768 executes in 2.38 ms, but requires 2,272 bytes of wire payload.

Protocol Architecture	Mean Time (ms)	Std Dev (ms)	Payload (Bytes)	Handshake Passes
Ju-Park 2023 (Reference)	0.82	0.04	384	4
ECC P-256 (Baseline)	4.15	0.15	192	2
Proposed Reduced-RTT	**0.61**	**0.03**	**288**	**3**
ML-KEM-768 (Post-Quantum)	2.38	0.08	2,272	2

Table II: Host Performance Benchmarks (Statistical Mean over 1,000 Deterministic Runs).

B. IoT Wireless Airtime Latency & MCU Energy Consumption

Physical layer airtime transmission latencies across LoRaWAN EU868 (10 kbps), NB-IoT Band 20 (50 kbps), LTE-M Cat-M1 (300 kbps), and 5G URLLC (5 Mbps) were quantified. In NB-IoT, our proposed Reduced-RTT scheme achieves 46.1 ms airtime (compared to 61.4 ms for Ju-Park). In contrast, ML-KEM-768 requires 358.4 ms in NB-IoT and 1.79 seconds in LoRaWAN due to payload fragmentation across 242-byte MTU boundaries.

On the ARM Cortex-M4 microcontroller, total energy consumption per handshake (E_total = E_comp + E_tx) under NB-IoT is: Proposed Reduced-RTT = 73.6 uJ (18.3 uJ comp + 55.3 uJ tx); Ju-Park 2023 = 98.3 uJ; ECC P-256 = 161.4 uJ; ML-KEM-768 = 507.6 uJ. Operating on a standard 220 mAh CR2032 coin cell at 24 handshakes per day, the proposed scheme guarantees an operational device battery lifespan of 6.2 years.

C. Formal Verification (ProVerif 2.05) & Adversarial Threat Simulation

All protocols were evaluated across 7 empirical Dolev-Yao attack vectors: replay attack, stale timestamp (>5s), packet bit-flipping, forged user impersonation, MitM server impersonation, nonce collision, and session key equality. All 7 attack scenarios were 100% intercepted and rejected with sub-millisecond detection.

Furthermore, we authored applied pi-calculus models in Inria ProVerif 2.05 [2] modeling unbounded interleaved sessions. All 13 formal query theorems proved true without counterexamples: query not attacker(SK[]) proved secrecy of session keys, and query inj-event(endU) ==> inj-event(beginCS) proved replay-free mutual authentication.

V. CONCLUSION

This research presented CryptoMAKA Lab, a comprehensive empirical and formal verification platform evaluating lightweight mutual authentication protocols for Cloud-IoT networks. By resolving the specification ambiguities of the Ju-Park 2023 protocol through constant-time 256-bit normalization, we established a reproducible baseline. Our proposed Reduced-Round-Trip (3-pass) extension reduces wireless airtime latency by 25% to 33% and requires only 73.6 uJ of total handshake energy on ARM Cortex-M4 microcontrollers, extending projected IoT battery longevity beyond 6 years. Formal symbolic verification in ProVerif verified 13 out of 13 security theorems under Dolev-Yao channel control. Furthermore, our post-quantum integration of NIST FIPS 203 ML-KEM-768 revealed that while lattice encapsulation offers quantum immunity, its 2.2 KB wire footprint imposes severe transmission airtime delays in LPWAN channels, necessitating specialized edge caching.

VI. DATA AVAILABILITY AND CODE AVAILABILITY

The complete source code, formal ProVerif models, vector diagrams, and synthetic benchmark datasets are openly available in the project repository: https://github.com/SuryaRaikuni/CNS/releases/tag/v0.1.0. The synthetic telemetry dataset consisting of 1,000 benchmark traces is archived under Review_3_Submission/4_Supplementary_Files/01_Dataset_Details/.

VII. AUTHOR CONTRIBUTIONS

Surya Pratap Singh Raikuni (24BYB1114) was responsible for conceptualization, formal mathematical modeling, software implementation of cryptographic protocols, formal ProVerif proofs, adversarial attack testbed development, experimental benchmark execution, and manuscript drafting. **Dr. Karthika V** served as faculty research supervisor, providing technical guidance, experimental design validation, formal verification review, manuscript critique, and final review supervision.

VIII. REFERENCES

[1] S. Ju and Y. Park, ``Provably secure lightweight mutual authentication and key agreement scheme for cloud-based IoT environments," *Sensors*, vol. 23, no. 24, p. 9766, 2023. DOI: 10.3390/s23249766.

[2] B. Blanchet, ``Modeling and verifying security protocols with the applied pi calculus and ProVerif," *Foundations and Trends in Privacy and Security*, vol. 1, no. 1--2, pp. 1--135, 2016. DOI: 10.1561/3300000004.

[3] National Institute of Standards and Technology (NIST), ``Module-Lattice-Based Key-Encapsulation Mechanism Standard," *NIST FIPS PUB 203*, Aug. 2024. DOI: 10.6028/NIST.FIPS.203.

[4] D. Dolev and A. C. Yao, ``On the security of public key protocols," *IEEE Transactions on Information Theory*, vol. 29, no. 2, pp. 198--208, 1983. DOI: 10.1109/TIT.1983.1056650.

[5] S. Challa, A. K. Das, V. Odelu, N. Kumar, S. Kumari, and M. K. Khan, ``An efficient ECC-based provably secure three-factor user authentication and key agreement protocol for cloud-based IoT," *IEEE Trans. Inf. Forensics Security*, vol. 13, no. 11, pp. 2785--2799, 2018. DOI: 10.1109/TIFS.2018.2831478.

[6] E. Rescorla, ``The Transport Layer Security (TLS) Protocol Version 1.3," *IETF RFC 8446*, Aug. 2018. DOI: 10.17487/RFC8446.

[7] M. Turkanovi■, B. Brumen, and M. Hölbl, ``A novel user authentication and key agreement scheme for heterogeneous ad hoc wireless sensor networks, based on the Internet of Things notion," *Ad Hoc Networks*, vol. 20, pp. 96--112, 2014. DOI: 10.1016/j.adhoc.2014.03.009.

[8] R. Amin and G. P. Biswas, ``A secure light weight scheme for user authentication and key agreement in multi-gateway based wireless sensor networks," *Ad Hoc Networks*, vol. 36, pp. 58--80, 2016. DOI: 10.1016/j.adhoc.2015.05.020.

[9] S. Meier, B. Schmidt, C. Cremers, and D. Basin, ``The TAMARIN Prover for the symbolic analysis of security protocols," in *Computer Aided Verification (CAV)*, LNCS 8044, Springer, pp. 696--701, 2013. DOI: 10.1007/978-3-642-39799-8_48.

[10] C. J. F. Cremers, ``The Scyther Tool: Verification, falsification, and analysis of security protocols," in *Computer Aided Verification (CAV)*, LNCS 5123, Springer, pp. 414--418, 2008. DOI: 10.1007/978-3-540-70545-1_38.